Exploitation Against the Clock:

Xiaomi S3 Smartwatch

by Sergei Volokitin

whoami

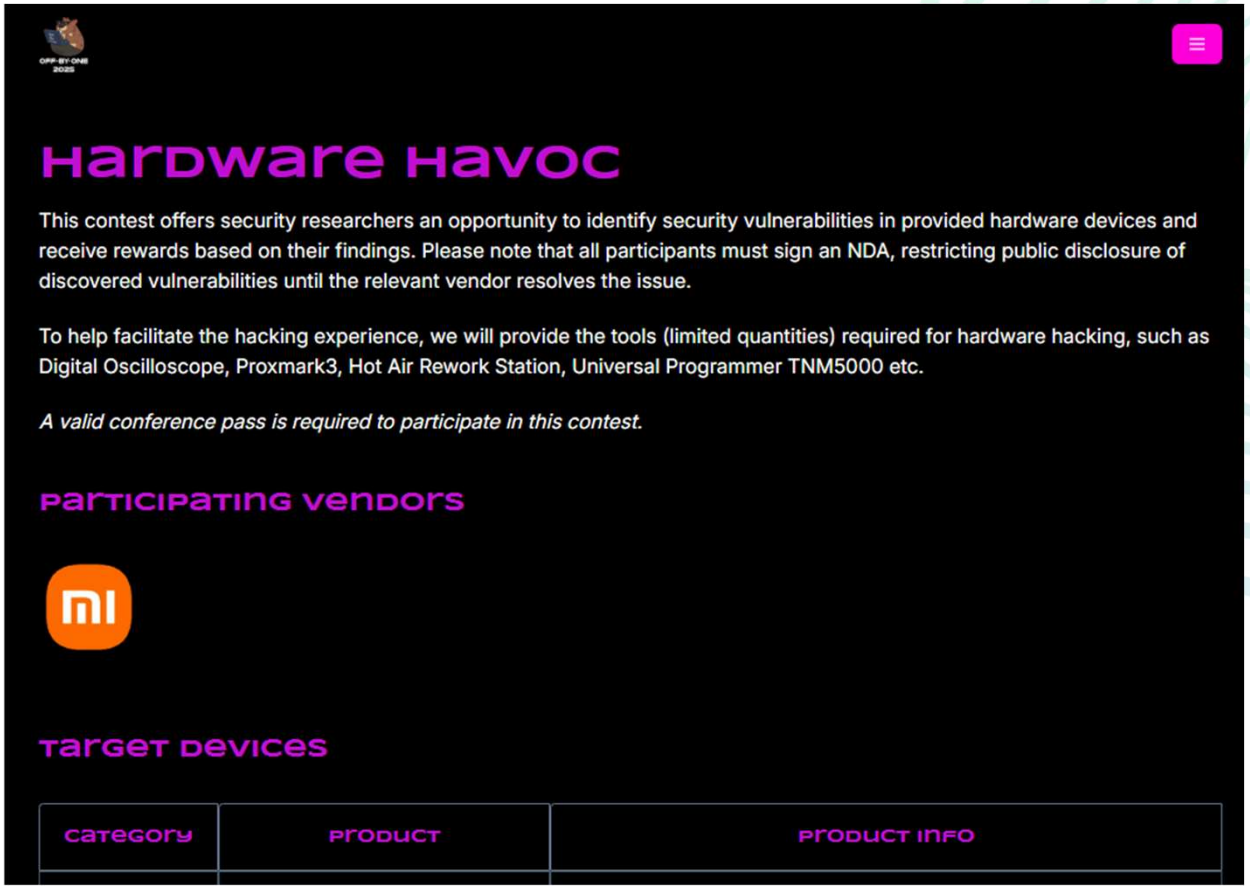
- Independent Security Researcher (Hexplot)
  - Mobile
  - Embedded devices
  - Secure elements
  - Hardware wallets
- Bug Bounties and Security Consultancy

Hardware Hacking

- Last November at Hardwear.io conference
- 3 days to find vulnerabilities, exploit and report it to the vendor



Hardware Havoc



Hardware Havoc

This contest offers security researchers an opportunity to identify security vulnerabilities in provided hardware devices and receive rewards based on their findings. Please note that all participants must sign an NDA, restricting public disclosure of discovered vulnerabilities until the relevant vendor resolves the issue.

To help facilitate the hacking experience, we will provide the tools (limited quantities) required for hardware hacking, such as Digital Oscilloscope, Proxmark3, Hot Air Rework Station, Universal Programmer TNM5000 etc.

A valid conference pass is required to participate in this contest.

Participating Vendors

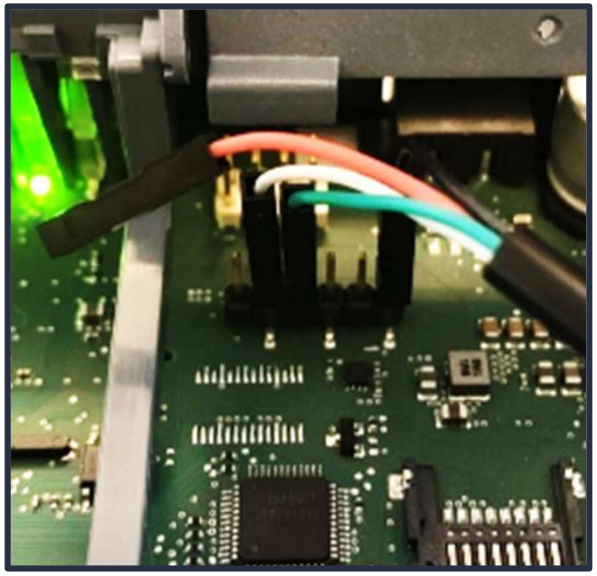
Target Devices

Category	Product	Product Info

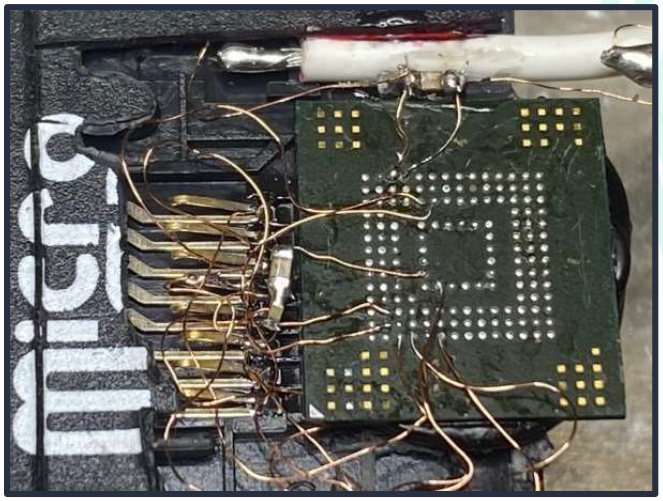
Hardware Hacking



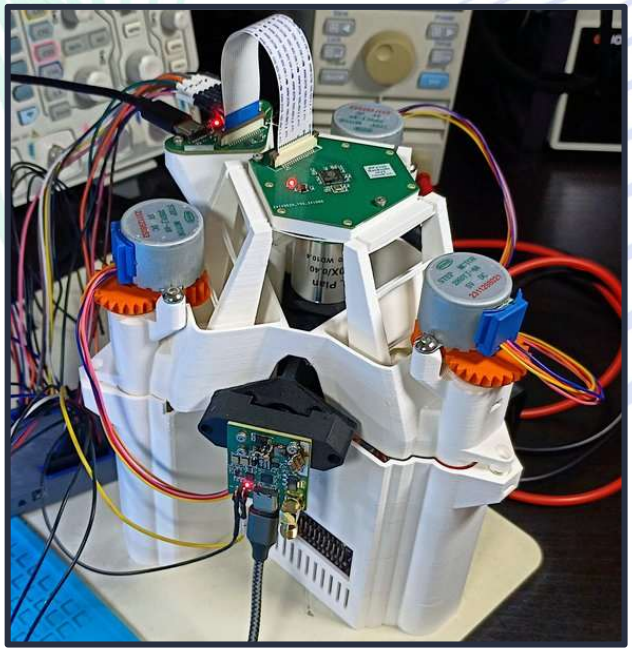
Hardware Hacking



https://support.kaspersky.com/iot-secure-gateway-100/2.0/240891



https://hackaday.com/2022/10/11/dumping-an-emmc-chip-with-many-bodge-wires/



https://courk.cc/rp2350-challenge-laser

Why Hardware Hacking?

- Bypassing DRM
- Stepping stone for future research
- Protecting from physical attackers

Xiaomi Outdoor Camera BW500



Xiaomi Outdoor Camera BW500

- Explored the interfaces and the internal components
- Camera runs U-Boot from SPI memory
- Loads Linux OS from flash
- Interacts with the backend over Wi-Fi

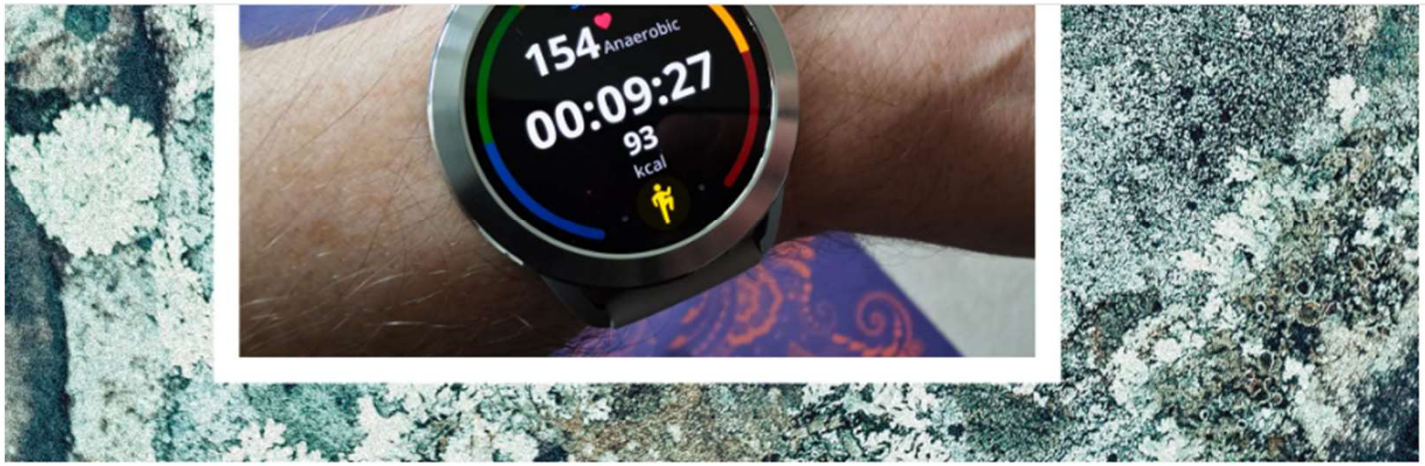
Xiaomi Outdoor Camera BW500

- Recovered content from the camera
- Found AI module (vehicle/pet/person/package)
- Found two user tokens saved in the filesystem



WIRED

FEATURED SUPERHUMAN GADGETS DINOSAUR CHOIR BUY IT FOR LIFE AIRPORT THEORY TI



IMON HILL: GETTY IMAGES

Rating: 6/10 ⓘ

WIRED	TIRED
Affordable. Changeable bezels. Impressive battery life (four to five days with everything turned on). Decent health, fitness, and sleep tracking.	No third-party apps. Xiaomi's software lacks polish. Chunky case.

No third-party apps. Xiaomi's software lacks polish. Chunky case.

Features

Watch Features:

- Text, calls, calendar
- Fitness, health data
- Payment cards
- BLE unlock of your Xiaomi phone

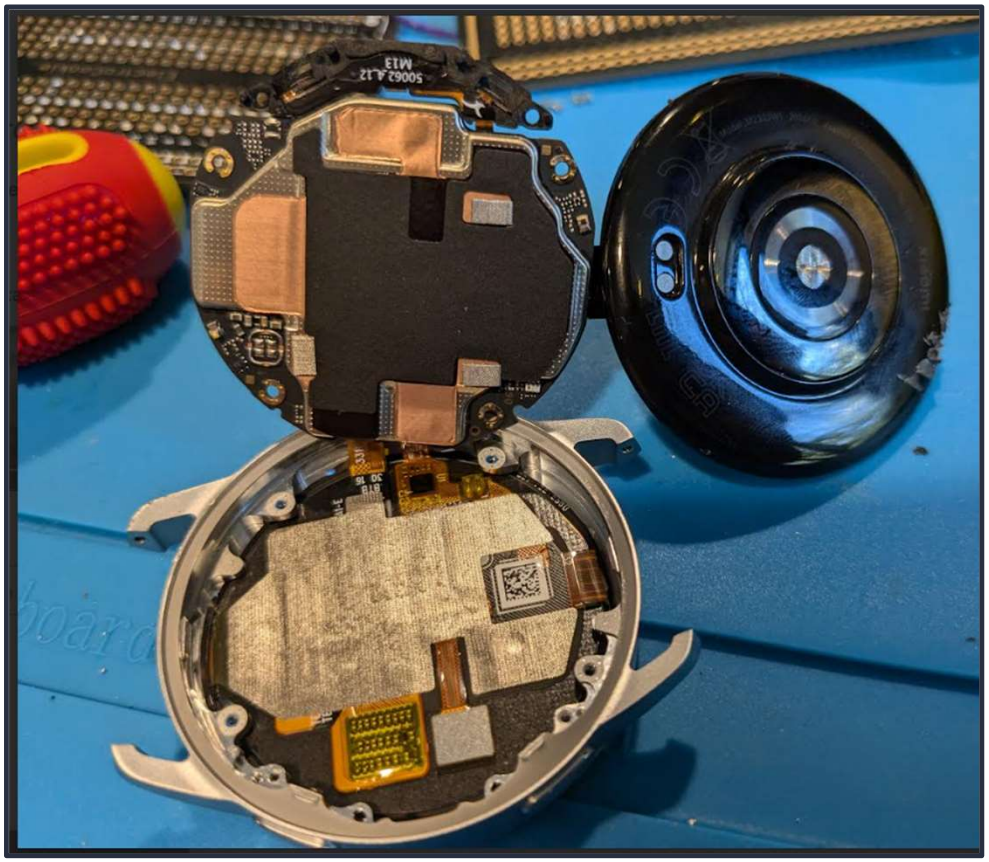
Security Mechanisms:

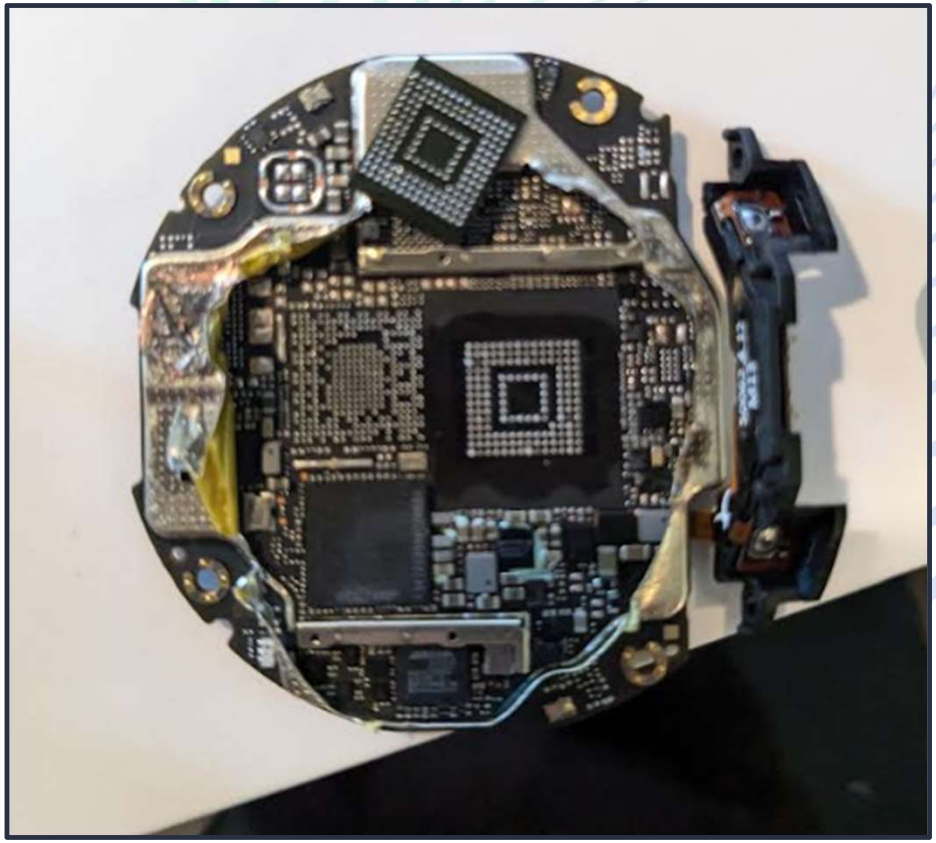
- PIN, Pattern
- On wrist detection
- Trusted Execution Environment
- Secure Element for payment

Interfaces



Hardware way



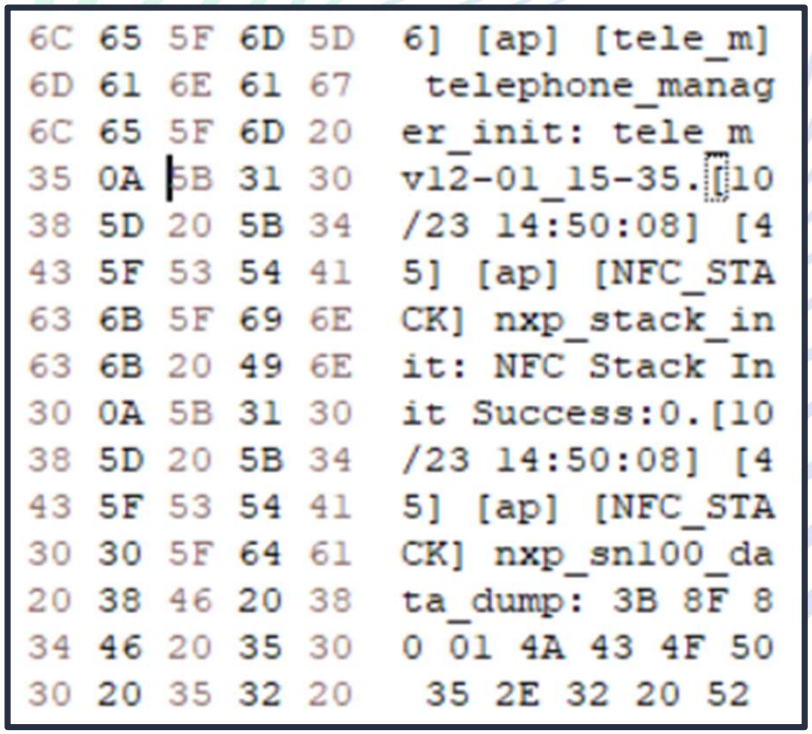


eMMC memory contents

- One of the partitions is called Coredump

*	LUN	Name	Offset	Size	Comment
☐	ROM1	GPTTable0	0x0000000000	1.0MB	
☐	ROM1	RECOVERY	0x0000100000	7.0MB	RAW
☐	ROM1	SYSTEM	0x0000800000	60.0MB	FS:Linux EXT
☐	ROM1	AI	0x0004400000	30.0MB	FS:Linux EXT
☐	ROM1	UPDATE	0x0006200000	45.0MB	FS:Linux EXT
☐	ROM1	DATA	0x0008F00000	157.0MB	FS:Linux EXT
☐	ROM1	SDCARD	0x0012C00000	6.906GB	FS:Linux EXT

- exFAT partition
- Contains logs from previous executions ✅
- Does not contain user PIN ❌



How many real time operating systems your smartwatch has?



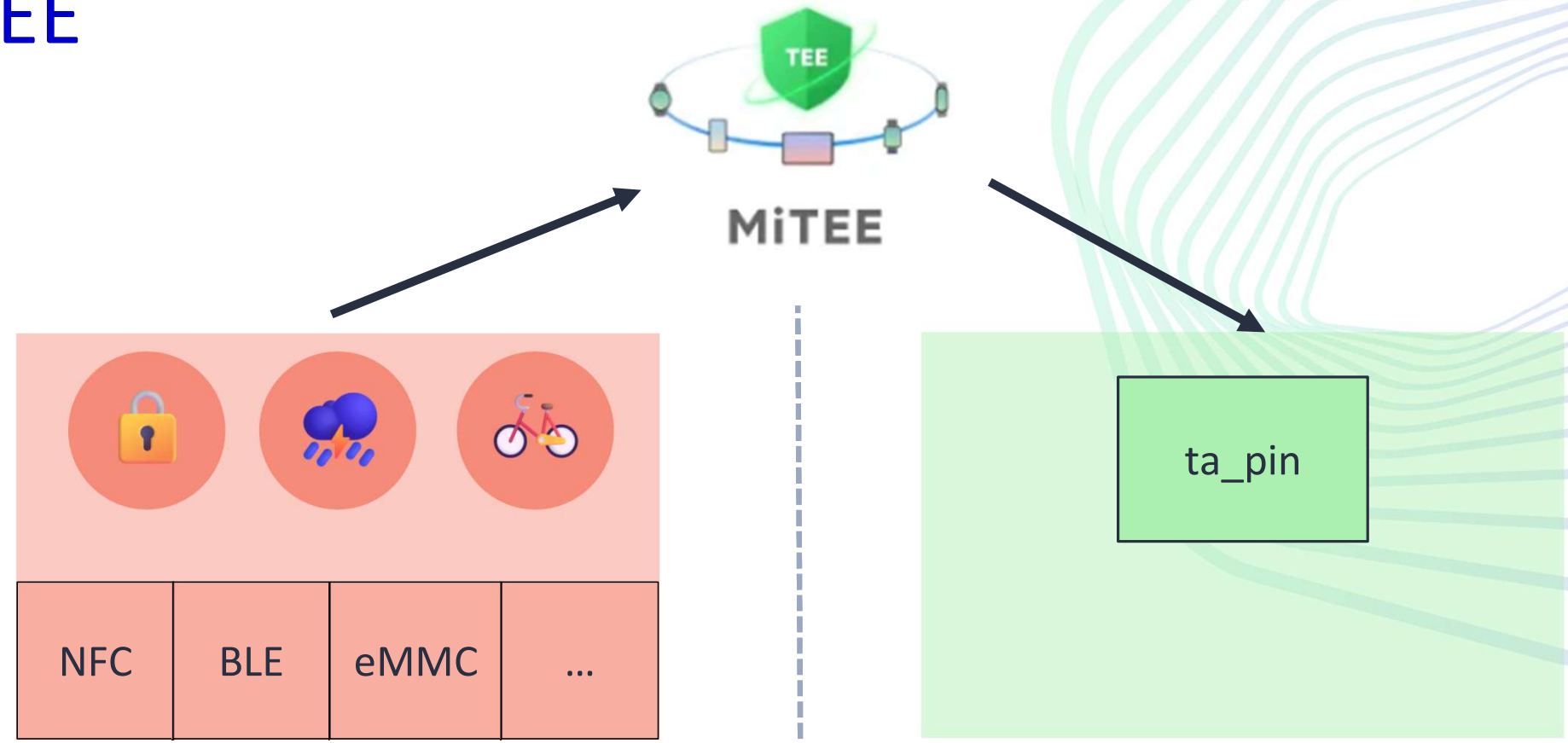
Apollo Guidance Computer had one RTOS to land on the Moon

How many real time operating systems your smartwatch has?

Modern Smart Watch has more then 4 RTOS

```
[ 5] [tee] NuttX Xiaomi Watch S3 3.6.1 66cbe7771a Mar 11 2024 20:38:50 arm tee
[12] [ap] NuttX Xiaomi Watch S3 3.6.1 66cbe7771a Mar 11 2024 20:36:22 arm ap
[ 6] [audio] NuttX Xiaomi Watch S3 3.6.1 66cbe7771a Mar 11 2024 20:45:08 xtensa audio
[ 8] [cp] NuttX Xiaomi Watch S3 3.6.1 66cbe7771a Mar 11 2024 20:50:40 arm cp
```

TEE



MiTEE is based on Apache NuttX RTOS

TA logs obfuscation

```
[tee] NuttX Xiaomi Watch S3 3.6.1 66cbe7771a Mar 11 2024 20:38:50 arm tee
[tee] [tee_server][E:src/mitee_server.c:189] 52c30453: 7
[tee] [tee_server][E:src/mitee_server.c:189] 52c30453: 11
[tee] [tee_server][E:src/mitee_server.c:189] 52c30453: 13
[tee] [tee_server][E:src/mitee_server.c:189] 52c30453: 15
[tee] [tee_server][E:src/mitee_server.c:189] 52c30453: 19
[tee] [tee_server][E:src/mitee_server.c:189] 52c30453: 21
[tee] [tee_server][E:src/mitee_server.c:189] 52c30453: 23
[tee] [tee_server][E:src/mitee_server.c:189] 52c30453: 27
[tee] [tee_server][E:src/mitee_server.c:189] 52c30453: 29
[tee] [tee_server][E:src/mitee_server.c:189] 52c30453: 31
```

Error message CRC?

Error code?

The Log

```
[10/23 14:56:13] [46] [ap] [pagemanager] on_ui_destroy: delete view 0x3ced5cb0:{2, 1}
[10/23 14:56:13] [46] [ap] [pagemanager] page_out_anim_ready_cb: page out animation ended
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report: down: id 0, x 226, y 436
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report: move: id 0, x 226, y 436
[10/23 14:56:13] [46] [ap] [touch] touchpad_read: pressed
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report:  up: id 0, x 226, y 436
[10/23 14:56:13] [46] [ap] [touch] touchpad_read: released
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report: down: id 0, x 236, y 413
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report: move: id 0, x 236, y 413
[10/23 14:56:13] [46] [ap] [touch] touchpad_read: pressed
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report:  up: id 0, x 236, y 413
[10/23 14:56:13] [46] [ap] [touch] touchpad_read: released
[10/23 14:56:14] [46] [ap] [LockScreen] lockscreen_manager_verify_pin: succeeded to verify
[10/23 14:56:14] [46] [ap] [LockScreen] lockscreen_manager_verify_pin: succeeded to verify
[10/23 14:56:14] [46] [ap] [LockScreen] lockscreen_manager_unlock: screen is unlocked, tag=system_password
```

The Log

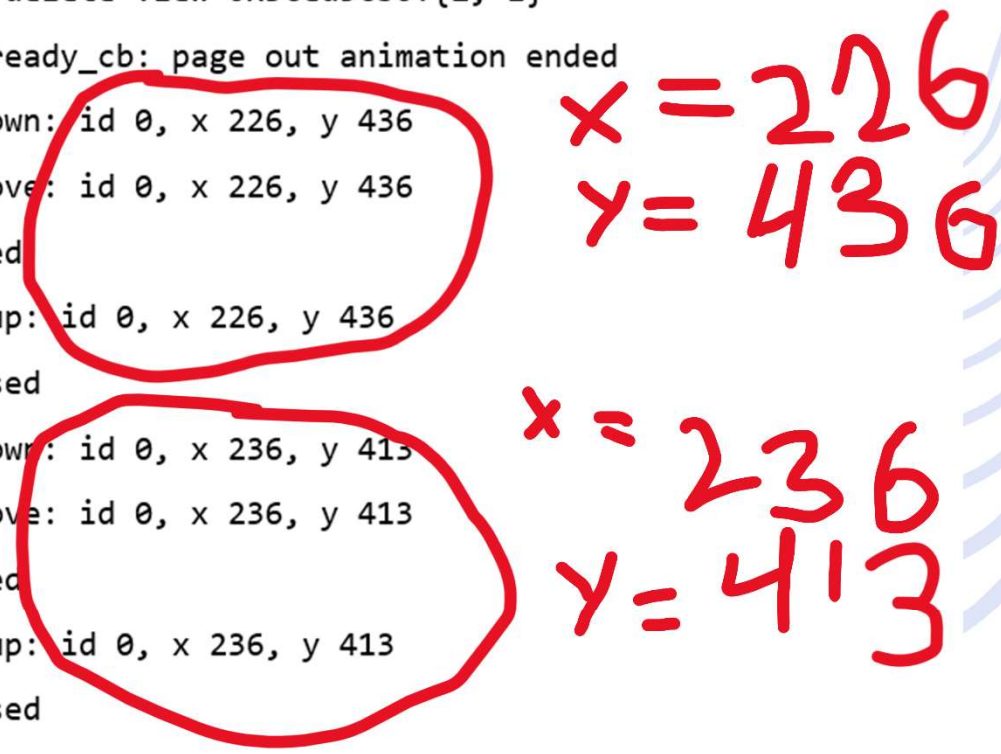
```
[10/23 14:56:13] [46] [ap] [pagemanager] on_ui_destroy: delete view 0x3ced5cb0:{2, 1}
[10/23 14:56:13] [46] [ap] [pagemanager] page_out_anim_ready_cb: page out animation ended
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report: down: id 0, x 226, y 436
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report: move: id 0, x 226, y 436
[10/23 14:56:13] [46] [ap] [touch] touchpad_read: pressed
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report:  up: id 0, x 226, y 436
[10/23 14:56:13] [46] [ap] [touch] touchpad_read: released
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report: down: id 0, x 236, y 413
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report: move: id 0, x 236, y 413
[10/23 14:56:13] [46] [ap] [touch] touchpad_read: pressed
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report:  up: id 0, x 236, y 413
[10/23 14:56:13] [46] [ap] [touch] touchpad_read: released
[10/23 14:56:14] [46] [ap] [LockScreen] lockscreen_manager_verify_pin: succeeded to verify
[10/23 14:56:14] [46] [ap] [LockScreen] lockscreen_manager_verify_pin: succeeded to verify
[10/23 14:56:14] [46] [ap] [LockScreen] lockscreen_manager_unlock: screen is unlocked, tag=system_password
```

The Log

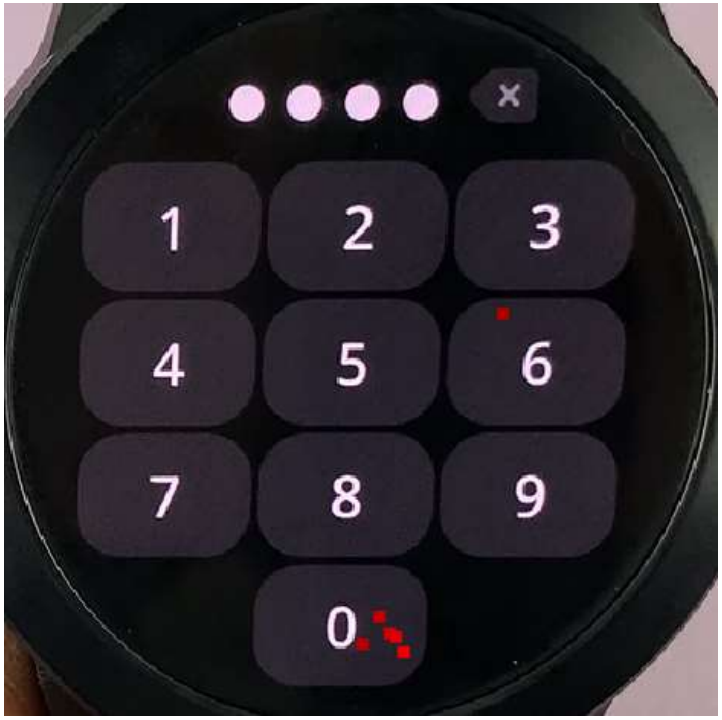
```
[10/23 14:56:13] [46] [ap] [pagemanager] on_ui_destroy: delete view 0x3ced5cb0:{2, 1}
[10/23 14:56:13] [46] [ap] [pagemanager] page_out_anim_ready_cb: page out animation ended
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report: down: id 0, x 226, y 436
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report: move: id 0, x 226, y 436
[10/23 14:56:13] [46] [ap] [touch] touchpad_read: pressed
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report:  up: id 0, x 226, y 436
[10/23 14:56:13] [46] [ap] [touch] touchpad_read: released
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report: down: id 0, x 236, y 413
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report: move: id 0, x 236, y 413
[10/23 14:56:13] [46] [ap] [touch] touchpad_read: pressed
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report:  up: id 0, x 236, y 413
[10/23 14:56:13] [46] [ap] [touch] touchpad_read: released
[10/23 14:56:14] [46] [ap] [LockScreen] lockscreen_manager_verify_pin: succeeded to verify
[10/23 14:56:14] [46] [ap] [LockScreen] lockscreen_manager_verify_pin: succeeded to verify
[10/23 14:56:14] [46] [ap] [LockScreen] lockscreen_manager_unlock: screen is unlocked, tag=system_password
```

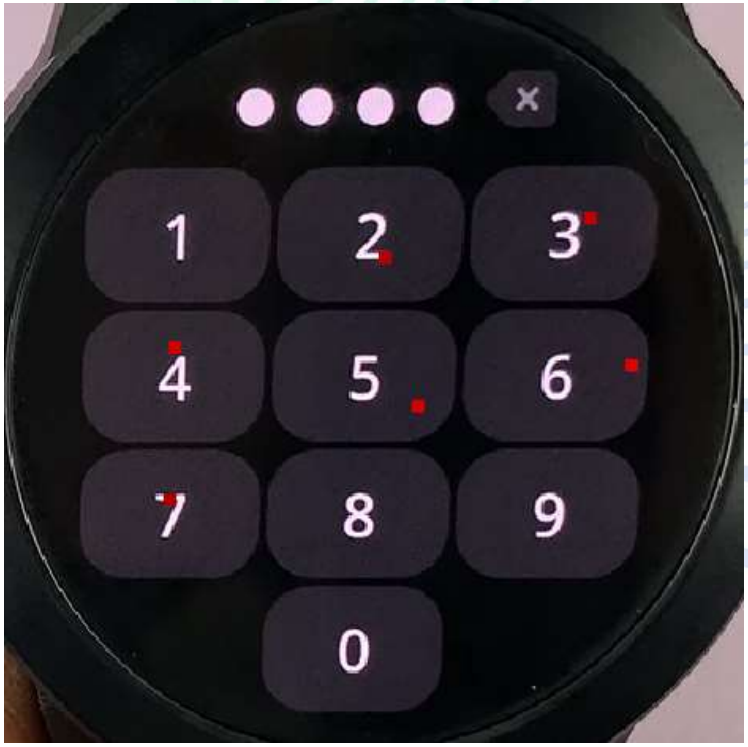
The Log

```
[10/23 14:56:13] [46] [ap] [pagemanager] on_ui_destroy: delete view 0x3ced5cb0:{2, 1}
[10/23 14:56:13] [46] [ap] [pagemanager] page_out_anim_ready_cb: page out animation ended
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report: down: id 0, x 226, y 436
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report: move: id 0, x 226, y 436
[10/23 14:56:13] [46] [ap] [touch] touchpad_read: pressed
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report:  up: id 0, x 226, y 436
[10/23 14:56:13] [46] [ap] [touch] touchpad_read: released
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report: down: id 0, x 236, y 413
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report: move: id 0, x 236, y 413
[10/23 14:56:13] [46] [ap] [touch] touchpad_read: pressed
[10/23 14:56:13] [ 1] [ap] tma525_parse_touch_report:  up: id 0, x 236, y 413
[10/23 14:56:13] [46] [ap] [touch] touchpad_read: released
[10/23 14:56:14] [46] [ap] [LockScreen] lockscreen_manager_verify_pin: succeeded to verify
[10/23 14:56:14] [46] [ap] [LockScreen] lockscreen_manager_verify_pin: succeeded to verify
[10/23 14:56:14] [46] [ap] [LockScreen] lockscreen_manager_unlock: screen is unlocked, tag=system_password
```



Full Pin recovery





Real life attack



Images are from thenounproject.com

Rating Hardware Vulnerabilities



How expensive?



iFixit Essential Electronics Toolkit

€29.99

iFixit Europe



Atten ST-8800D hete-lucht

€95.00 & more prices



Pine64 CN-versie Pinecil V1 soldeerbout Draagbare programmeerbare…

€34.19



Okdo USB3 eMMC Reader/Writer for ROCK, RA004

€9.39



@hexpl0t

Conclusions

- Debug features are against security
- Explore the unexpected
- Collaboration can improve security

Questions?